1. DNS Header

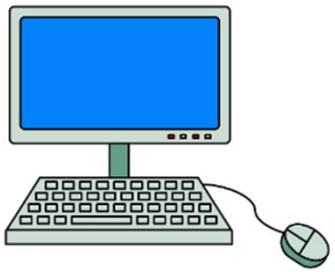
DNS(Domain Name Service)

- DNS 주소 조회 방법

  - 정방향 조회 : 문자주소를 기반으로 IP 주소를 조회

  - 역방향 조회 : IP주소를 기반으로 문자주소를 조회

    *DNS 클라이언트 : DNS 서버에게 DNS 서비스를 제공받는 컴퓨터



IP 192.168.1.10
SM 255.255.255.0
DNS 192.168.1.253
MAC 1111.2222.1111

- DNS query : DNS 클라이언트가 DNS 서버에게 보내는 질의 메시지
- DNS Response : DNS 서버가 DNS 클라이언트에게 보내는 응답 메세지

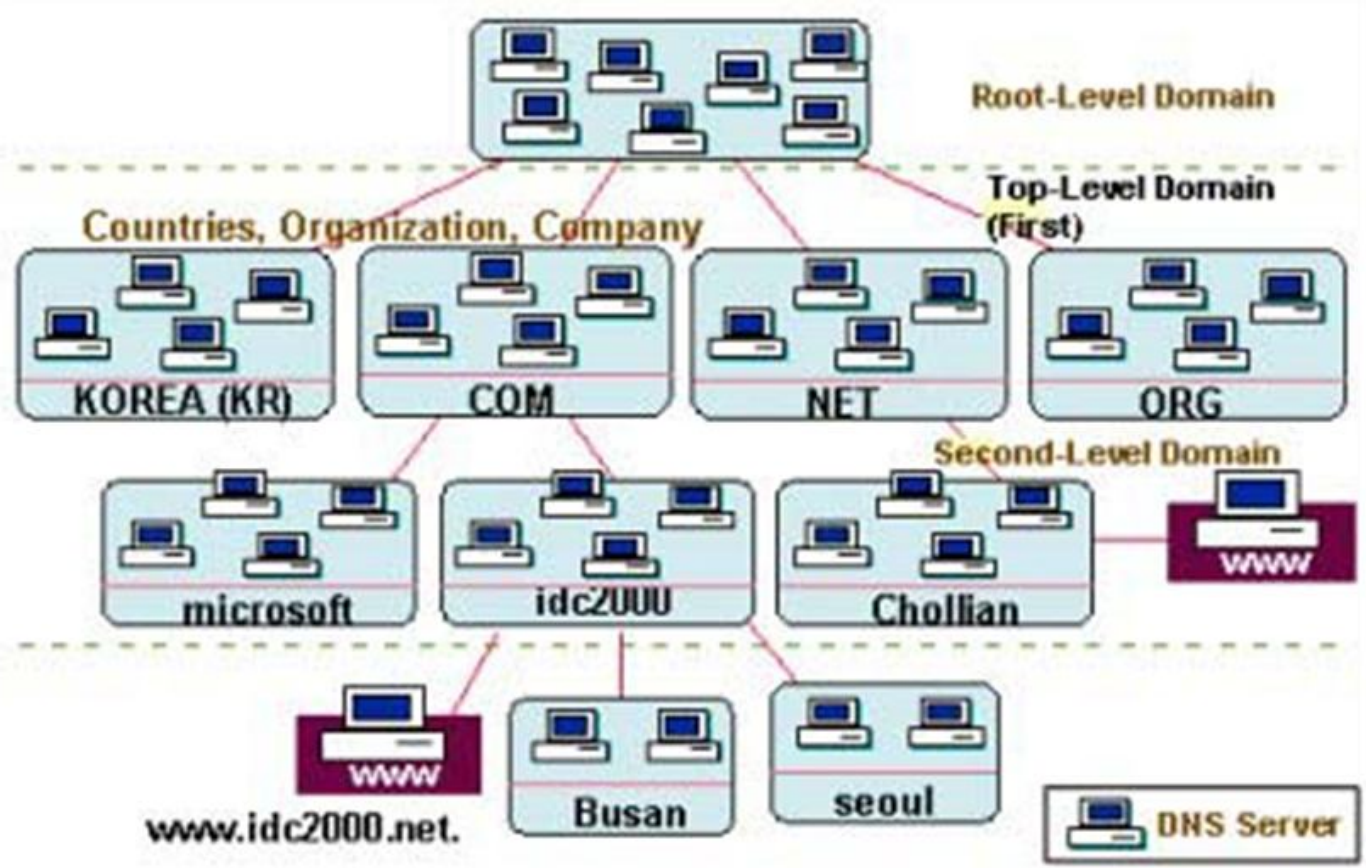
DNS Cache Table

- FQDN과 IP 주소의 대응 관계를 저장한 테이블
- 운영체제는 DNS 서버로부터 도메인 네임에 대한 IP 주소를 응답받으면 해당 내용을 DNS 캐시 테이블에 반영

ipconfig /displaydns

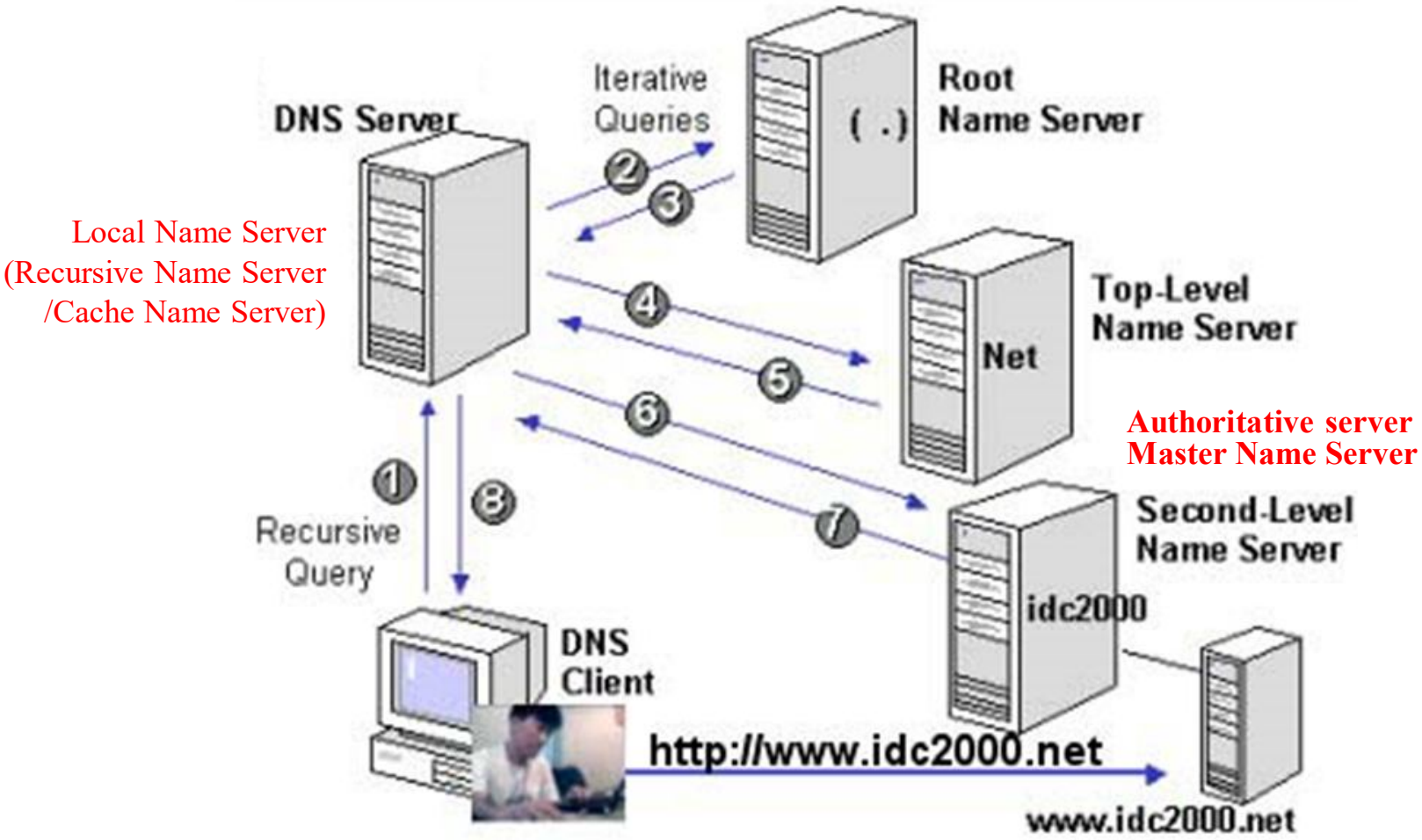
```
C:₩Users₩Owner>ipconfig/displaydns

Windows IP 구성

    l.kakao.com
    ----------------------------------------
    데이터 이름 . . . . . : l.kakao.com
    데이터 유형 . . . . . : 1
    TTL(Time To Live) . : 3269
    데이터 길이 . . . . . : 4
    섹션 . . . . . : 응답
    (호스트) 레코드 . . . : 211.231.108.197


    www.google.com
    ----------------------------------------
    데이터 이름 . . . . . : www.google.com
    데이터 유형 . . . . . : 1
    TTL(Time To Live) . : 189
    데이터 길이 . . . . . : 4
    섹션 . . . . . : 응답
    (호스트) 레코드 . . . : 216.58.197.132
```

DNS 구조 및 프로세스



* 분산 계층 데이타베이스 구조

DNS Name Resolution

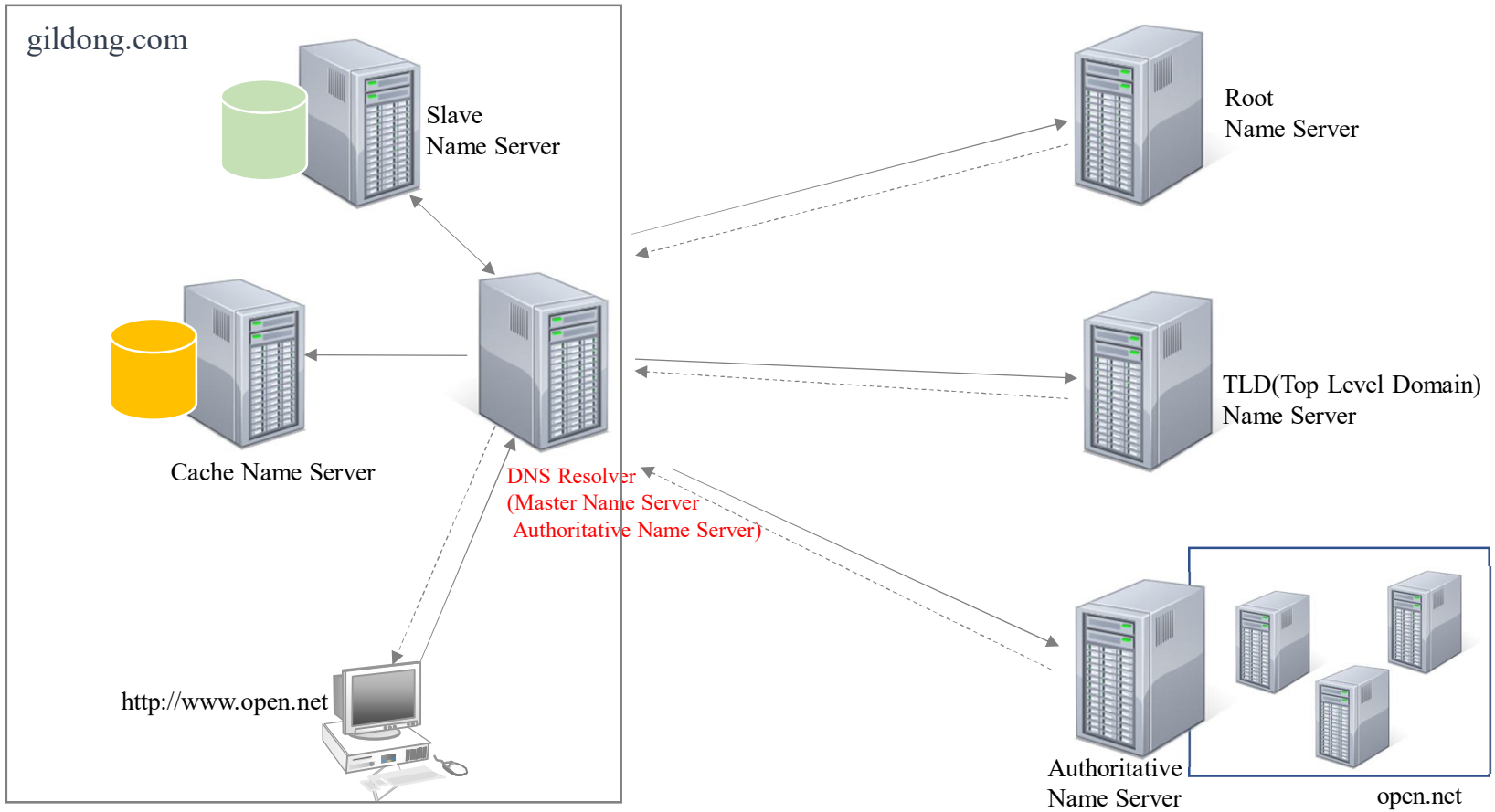


DNS 53 UDP/TCP

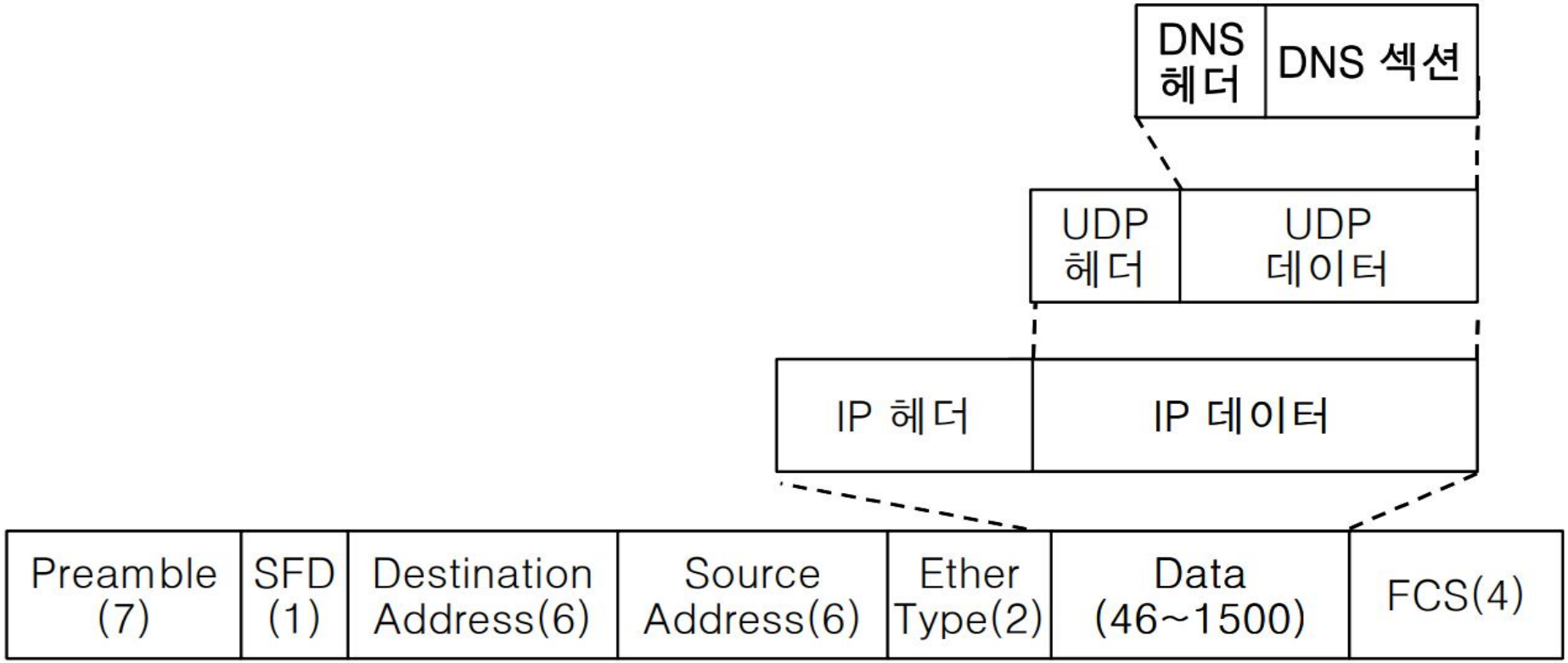
- UDP 혹은 TCP를 사용
- 포트번호 : 53
- 응답 메시지의 크기가 512 byte보다 작으면 UDP 사용

  - 최대 UDP 패키지의 크기가 512 byte로 제한되기 때문

  - 응답 메시지의 크기가 512 byte 이상이면 TCP 연결이 사용
- 대부분의 패킷이 UDP를 사용

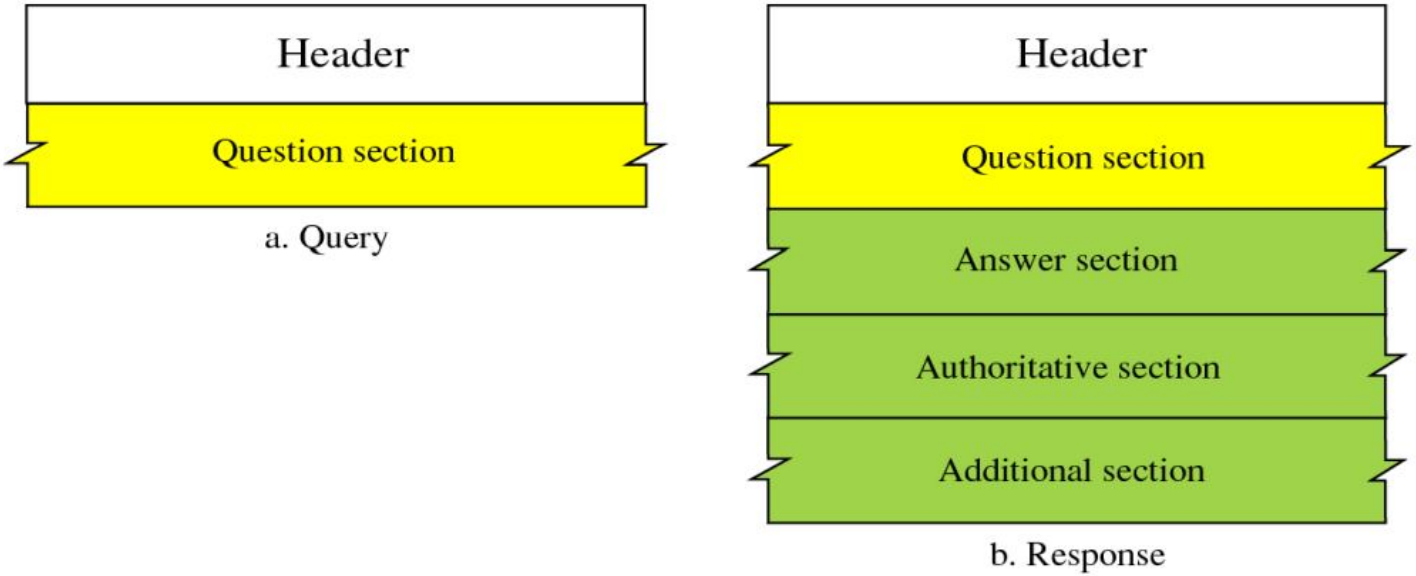

gildong.com
Slave
Name Server
Cache Name Server
DNS Resolver
(Master Name Server
Authoritative Name Server)
http://www.open.net
Root
Name Server
TLD(Top Level Domain)
Name Server
Authoritative
Name Server
open.net

DNS Header Structure

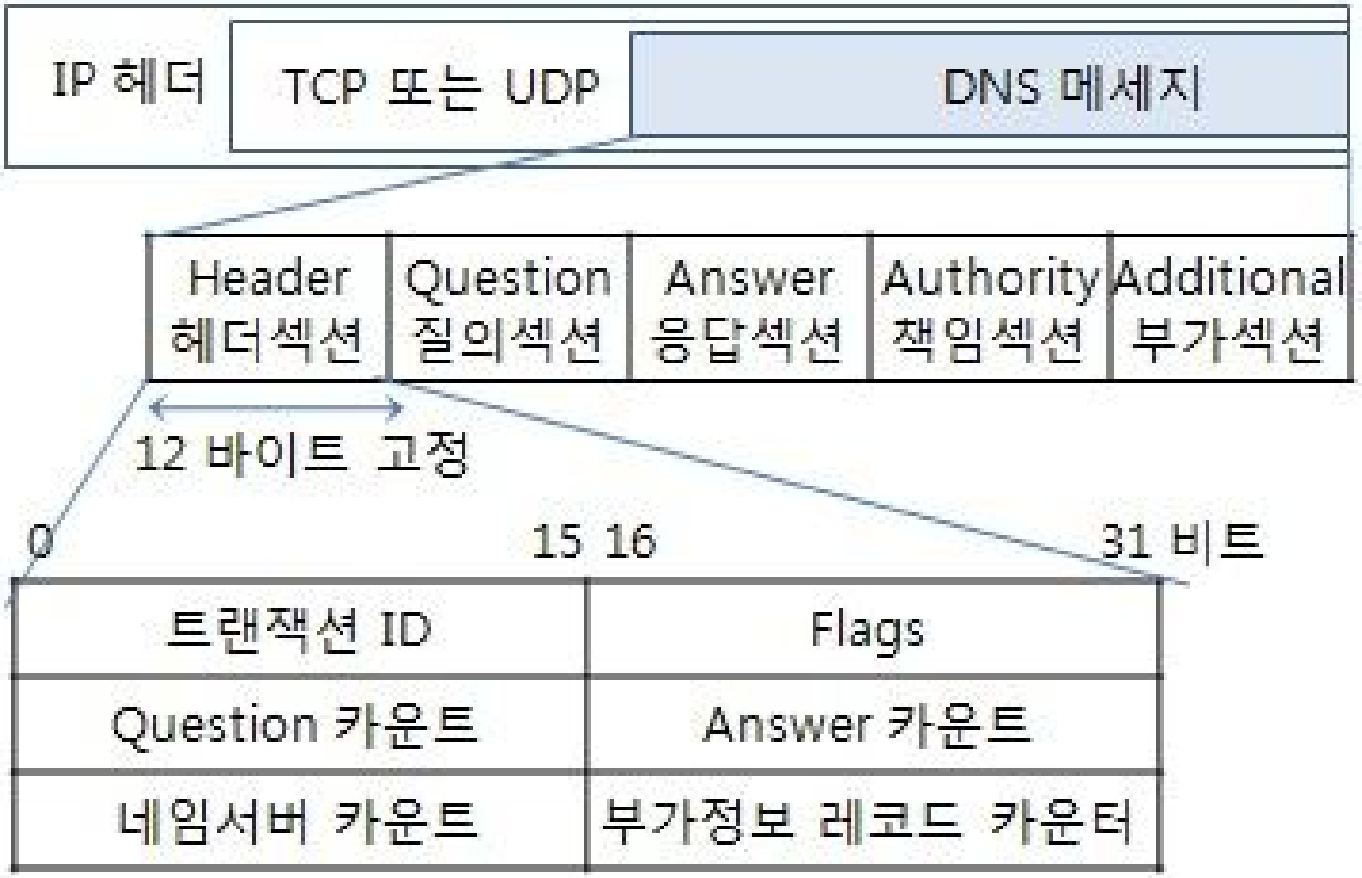


DNS Message

- 질의 메시지(Query message)
  - 헤더와 질의코드(question records)로 구성
- 응답 메시지(Response message)
  - 헤더와 질의 레코드, 응답 레코드, 권한 레코드. 추가적인 레코드로 구성



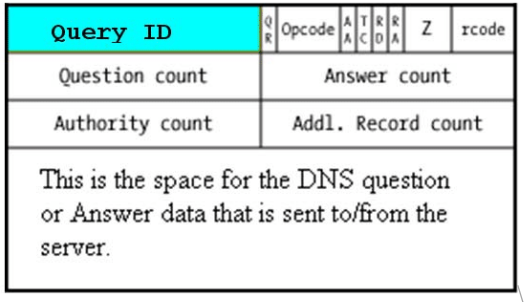
DNS Header


IP 헤더
TCP 또는 UDP
DNS 메세지
Header
헤더섹션
Question
질의섹션
Answer
응답섹션
Authority
책임섹션
Additional
부가섹션
12 바이트 고정
0
15 16
31 비트
트랜잭션 ID
Flags
Question 카운트
Answer 카운트
네임서버 카운트
부가정보 레코드 카운터

DNS Message

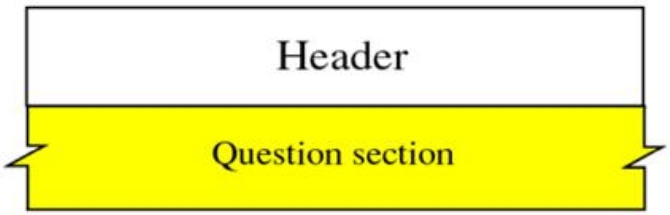
질의 섹션 (Question Section)	질의와 응답 메시지에 모두 존재
응답 섹션 (Answer Section)	응답메시지에 존재하고 서버로부터 클라이언트로의 응답을 포함
권한 섹션 (Authoritative Section)	응답메시지에만 존재 질의에 대해 권한이 있는 서버에 대한 정보(도메인 이름)를 제공
추가적인 정보 섹션 (Additional Section)	응답 메시지에만 존재 해석기(resolver)에서 도움이 될 만한 추가적인 정보들을 제공

DNS Header




```
Domain Name System (query)
    Transaction ID: 0x8b34
    Flags: 0x0100 Standard query
        0... .... .... .... = Response: Message is a query
        .000 0... .... .... = Opcode: Standard query (0)
        .... ..0. .... .... = Truncated: Message is not truncated
        .... ...1 .... .... = Recursion desired: Do query recursively
        .... .... .0.. .... = Z: reserved (0)
        .... .... ...0 .... = Non-authenticated data: Unacceptable
    Questions: 1
    Answer RRs: 0
    Authority RRs: 0
    Additional RRs: 0
    Queries
        www.nostarch.com: type A, class IN
            Name: www.nostarch.com
            [Name Length: 16]
            [Label Count: 3]
            Type: A (Host Address) (1)
            Class: IN (0x0001)
```

DNS Query Message




```
Domain Name System (query)
    Transaction ID: 0x180f
    Flags: 0x0100 Standard query
        0... .... .... .... = Response: Message is a query
        .000 0... .... .... = Opcode: Standard query (0)
        .... ..0. .... .... = Truncated: Message is not truncated
        .... ...1 .... .... = Recursion desired: Do query recursively
        .... .... .0.. .... = Z: reserved (0)
        .... .... ...0 .... = Non-authenticated data: Unacceptable
    Questions: 1
    Answer RRs: 0
    Authority RRs: 0
    Additional RRs: 0
```

Header

```
    Queries
        wireshark.org: type A, class IN
            Name: wireshark.org
            [Name Length: 13]
            [Label Count: 2]
            Type: A (Host Address) (1)
            Class: IN (0x0001)
```

Data

DNS Query Header

```
Transaction ID: 0x180f
Flags: 0x0100 Standard query
❶ 0... .... .... .... = Response: Message is a query
❷ .000 0... .... .... = Opcode: Standard query (0)
❸ .... ..0. .... .... = Truncated: Message is not truncated
❹ .... ...1 .... .... = Recursion desired: Do query recursively
  .... .... .0.. .... = Z: reserved (0)
  .... .... ...0 .... = Non-authenticated data: Unacceptable
Questions: 1
Answer RRs: 0
Authority RRs: 0
Additional RRs: 0
```

Transaction ID

- DNS를 구별하는 식별자 요청 메세지와 응답 메시지의 한 쌍을 의미하는 번호

❶ QR : Query/Response 메시지 종류(0:query, 1: Response)

❷ OPCode : 정방향조회:0, 역방향조회 : 1, 서버상태요청 : 2

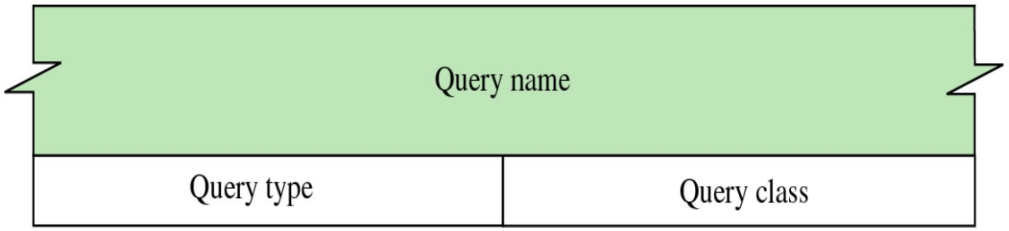
❸ TC : 응답이 512byte를 초과하여 512byte로 잘렸음을 나타냄

❹ RD : 응답결과를 얻을 때가지 반복적질의를 수행하도록 요청(요청메세지)

RA : DNS서버가 DNS 클라이언트의 반복질의요청을 수행할 수 있음을 의미 (응답메시지)

❺ 예약필드로 지정

DNS Query Data




```
Queries
  wireshark.org: type A, class IN
      Name: wireshark.org
      [Name Length: 13]
      [Label Count: 2]
      Type: A (Host Address) (1)
      Class: IN (0x0001)
```

❶ Query Name : 요청/응답 메시지에 사용, 요청/응답에 대한 도메인 명을 의미

❷ Type : 요청/응답 메시지의 사용, 레코드 타입

- A/NS(하나의 도메인을 관리하는 name server)/CNAME(호스트 별)/PTR/HINFO (호스트 하드웨어와 OS 관련 정보)

❸ Class : 프로토콜 패밀리를 의미, 인터넷을 사용할 경우 IN(Internet , 값은 1)을 사용

Record Type

A	도메인의 IP 주소를 갖고 있는 레코드
AAAA	도메인의 IPv6 주소를 포함하는 레코드 (IPv4 주소를 나열하는 A 레코드와 반대)
CNAME	메인의 정식 이름을 지정 하나의 도메인이나 하위 도메인을 다른 도메인으로 전달 IP 주소를 제공하지는 않음
MX	메일 서버에서 이메일을 전달할 위치를 결정하는 데 사용
NS	DNS 항목의 이름 서버를 저장
SOA	도메인에 대한 관리자 정보를 저장 - 관리자의 이메일 주소, 도메인이 마지막으로 업데이트된 시간, 새로 고침 사이에 서버가 대기해야 하는 시간 등
SRV	특정 서비스에 대한 포트를 지정
PTR	역방향 조회에서 도메인 이름을 제공

nslookup –type=a www.naver.com

```
C:\>nslookup -type=a www.naver.com
서버:    ns.dacom.co.kr
Address:  164.124.101.2

권한 없는 응답:
이름:    www.naver.com.nheos.com
Addresses:  223.130.200.104
          223.130.200.107
Aliases:  www.naver.com
```

nslookup –type=cname naver.com

```
C:\>nslookup -type=cname www.naver.com
서버:    ns.lgdacom.net
Address:  164.124.101.2

권한 없는 응답:
www.naver.com   canonical name = www.naver.com.nheos.com
```

nslookup –type=ns naver.com

```
C:\>nslookup -type=ns naver.com
서버:    ns.dacom.co.kr
Address:  164.124.101.2

권한 없는 응답:
naver.com       nameserver = ns1.naver.com
naver.com       nameserver = ns2.naver.com
```

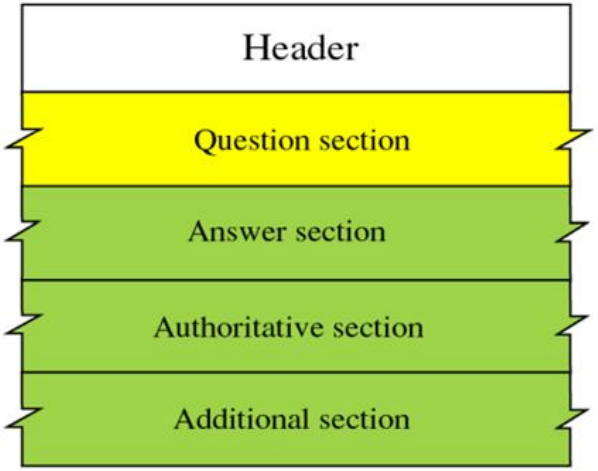
nslookup –type=soa naver.com

```
C:\>nslookup -type=soa naver.com
서버:    ns.lgdacom.net
Address:  164.124.101.2

권한 없는 응답:
naver.com
        primary name server = ns1.naver.com
        responsible mail addr = webmaster.naver.com
        serial  = 2024010902
        refresh = 21600 (6 hours)
        retry   = 1800 (30 mins)
        expire  = 1209600 (14 days)
        default TTL = 180 (3 mins)
```

nslookup –type=mx naver.com

```
C:\>nslookup -type=mx naver.com
서버:    ns.dacom.co.kr
Address:  164.124.101.2

권한 없는 응답:
naver.com       MX preference = 10, mail exchanger = mx1.naver.com
naver.com       MX preference = 10, mail exchanger = mx3.naver.com
naver.com       MX preference = 10, mail exchanger = mx2.naver.com
```

DNS Response Message




```
Domain Name System (response)
  Transaction ID: 0x180f
  Flags: 0x8180 Standard query response, No error
    1... .... .... .... = Response: Message is a response
    .000 0... .... .... = Opcode: Standard query (0)
    .... .0.. .... .... = Authoritative: Server is not an authority for domain
    .... ..0. .... .... = Truncated: Message is not truncated
    .... ...1 .... .... = Recursion desired: Do query recursively
    .... .... 1... .... = Recursion available: Server can do recursive queries
    .... .... .0.. .... = Z: reserved (0)
    .... .... ..0. .... = Answer authenticated: Answer/authority portion was not
    .... .... ...0 .... = Non-authenticated data: Unacceptable
    .... .... .... 0000 = Reply code: No error (0)
  Questions: 1
  Answer RRs: 1
  Authority RRs: 0
  Additional RRs: 0
```

Header

```
  Queries
    wireshark.org: type A, class IN
      Name: wireshark.org
      [Name Length: 13]
      [Label Count: 2]
      Type: A (Host Address) (1)
      Class: IN (0x0001)
```

Question

```
  Answers
    wireshark.org: type A, class IN, addr 128.121.50.122
      Name: wireshark.org
      Type: A (Host Address) (1)
      Class: IN (0x0001)
      Time to live: 14400 (4 hours)
      Data length: 4
      Address: 128.121.50.122
```

Answer

DNS Response Header

```
  Transaction ID: 0x180f
✓ Flags: 0x8180 Standard query response, No error
    1... .... .... .... = Response: Message is a response
    .000 0... .... .... = Opcode: Standard query (0)
    .... .0.. .... .... = Authoritative: Server is not an authority for domain
    .... ..0. .... .... = Truncated: Message is not truncated
    .... ...1 .... .... = Recursion desired: Do query recursively
    .... .... 1... .... = Recursion available: Server can do recursive queries
    .... .... .0.. .... = Z: reserved (0)
    .... .... ..0. .... = Answer authenticated: Answer/authority portion was not
    .... .... ...0 .... = Non-authenticated data: Unacceptable
    .... .... .... 0000 = Reply code: No error (0)
  Questions: 1
  Answer RRs: 1
  Authority RRs: 0
  Additional RRs: 0
```

- RCODE (Reply code) : 응답에서 오류가 존재하는지를 표시

0	NoError	오류 없음
1	FormErr	형식 오류 (쿼리가 잘못된 경우)
2	ServFai	서버 실패 (DNS 서버 자체의 문제로 실패)
3	NXDomain	네임 오류 (도메인 네임이 존재하지 않는 경우)
4	NotImp	DNS 서버가 Query를 지원하지 못함
5	Refused	거부 (정책적인 이유로 Query를 거절함)

```
Domain Name System (response)
  Transaction ID: 0x180f
  Flags: 0x8180 Standard query response, No error
  Questions: 1
  Answer RRs: 1
  Authority RRs: 0
  Additional RRs: 0
  Queries
  Answers
    wireshark.org: type A, class IN, addr 128.121.50.122
      Name: wireshark.org
      Type: A (Host Address) (1)
      Class: IN (0x0001)
      Time to live: 14400 (4 hours)
      Data length: 4
      Address: 128.121.50.122
```

DNS Response

```
Domain Name System (response)
  Transaction ID: 0x180f
  Flags: 0x8180 Standard query response, No error
  Questions: 1
  Answer RRs: 1
  Authority RRs: 0
  Additional RRs: 0
  Queries
  Answers
    wireshark.org: type A, class IN, addr 128.121.50.122
      Name: wireshark.org
      Type: A (Host Address) (1)
      Class: IN (0x0001)
      Time to live: 14400 (4 hours)
      Data length: 4
      Address: 128.121.50.122
```

Domain name	가변 길이를 가지며 도메인 네임을 포함
Domain Type	질의 섹션에 있는 질의 종류 필드와 동일하나 마지막 두 종류만 허락되지 않음
Domain Class	질의 섹션에 있는 클래스 필드와 동일
Time to Live	이 정보가 로컬 호스트에 캐시 되는 경우에 얼마간 이용될 수 있는가를 나타내며 보통 2일간을 나타냄
Data Length	자원 데이터의 길이를 나타냄, 요구한 정보의 유형에 따라 다름 유형 1(A 레코드)일 경우 자원데이터는 4-byte IP 주소

DNS Query/Response Header

```
Domain Name System (query)
    Transaction ID: 0x180f
    Flags: 0x0100 Standard query
        0... .... .... .... = Response: Message is a query
        .000 0... .... .... = Opcode: Standard query (0)
        .... ..0. .... .... = Truncated: Message is not truncated
        .... ...1 .... .... = Recursion desired: Do query recursively
        .... .... .0.. .... = Z: reserved (0)
        .... .... ...0 .... = Non-authenticated data: Unacceptable
    Questions: 1          ❶
    Answer RRs: 0         ❷
    Authority RRs: 0      ❸
    Additional RRs: 0     ❹
    Queries
        wireshark.org: type A, class IN
            Name: wireshark.org
            [Name Length: 13]
            [Label Count: 2]
            Type: A (Host Address) (1)
            Class: IN (0x0001)
```

❶ 요청 메시지에 포함된 질의 개수(Number of Question Records)

❷ 응답 메세지에 포함된 응답 개수(Number of Answer Records)

❸ 응답 메시지에 포함된 도메인을 관리하는 네임서버의 개수(Number of Authoritative Records)

❹ 응답 메시지에 포함된 추가적인 정보의 개수 (Number of Additional Records)

2. DNS 로그 분석

- DNS 네트워크 현황분석과 이상징후 분석

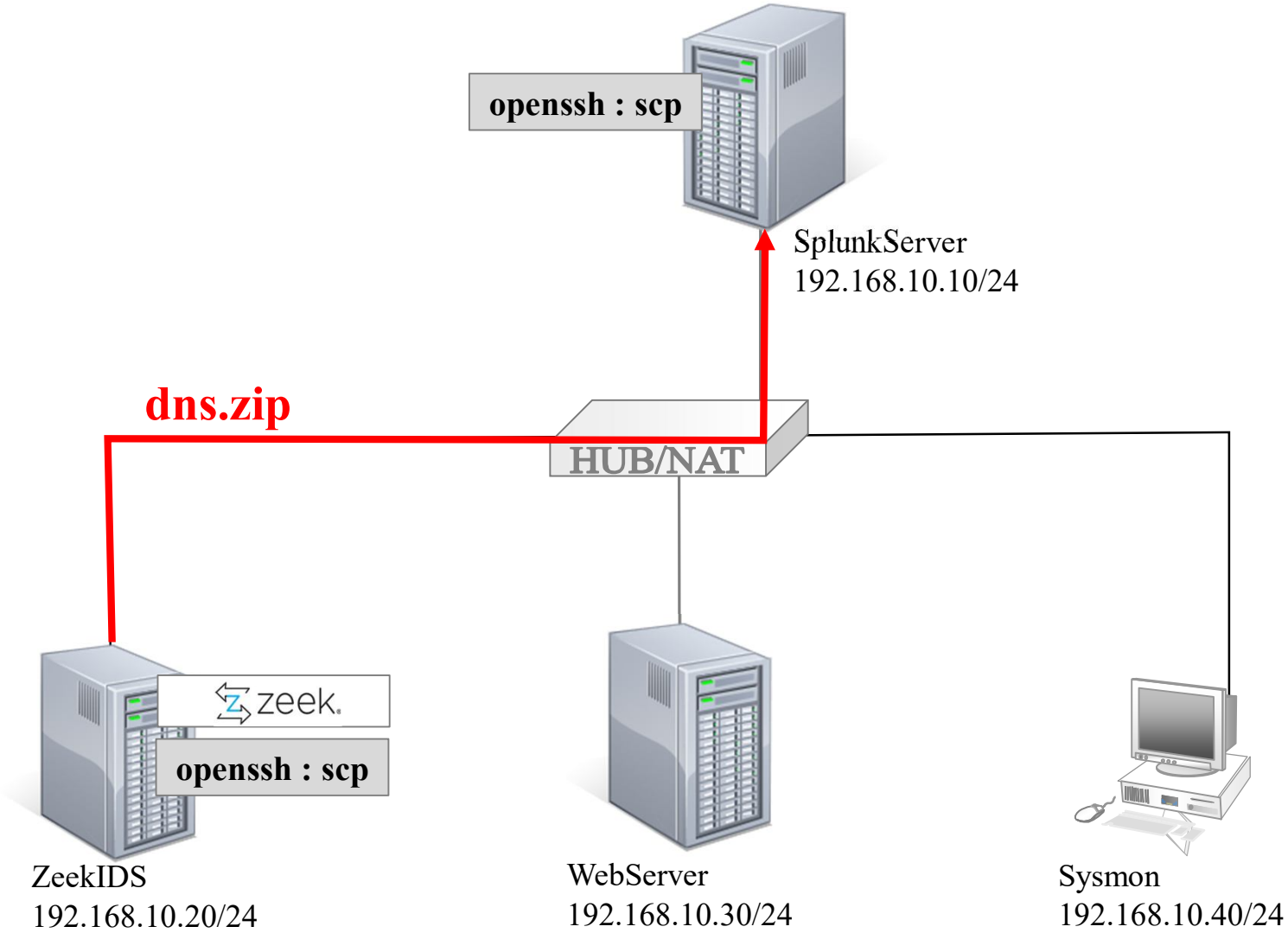
1) DNS Log 실습환경 구성

❶ Index 만들기 (로그 저장소)

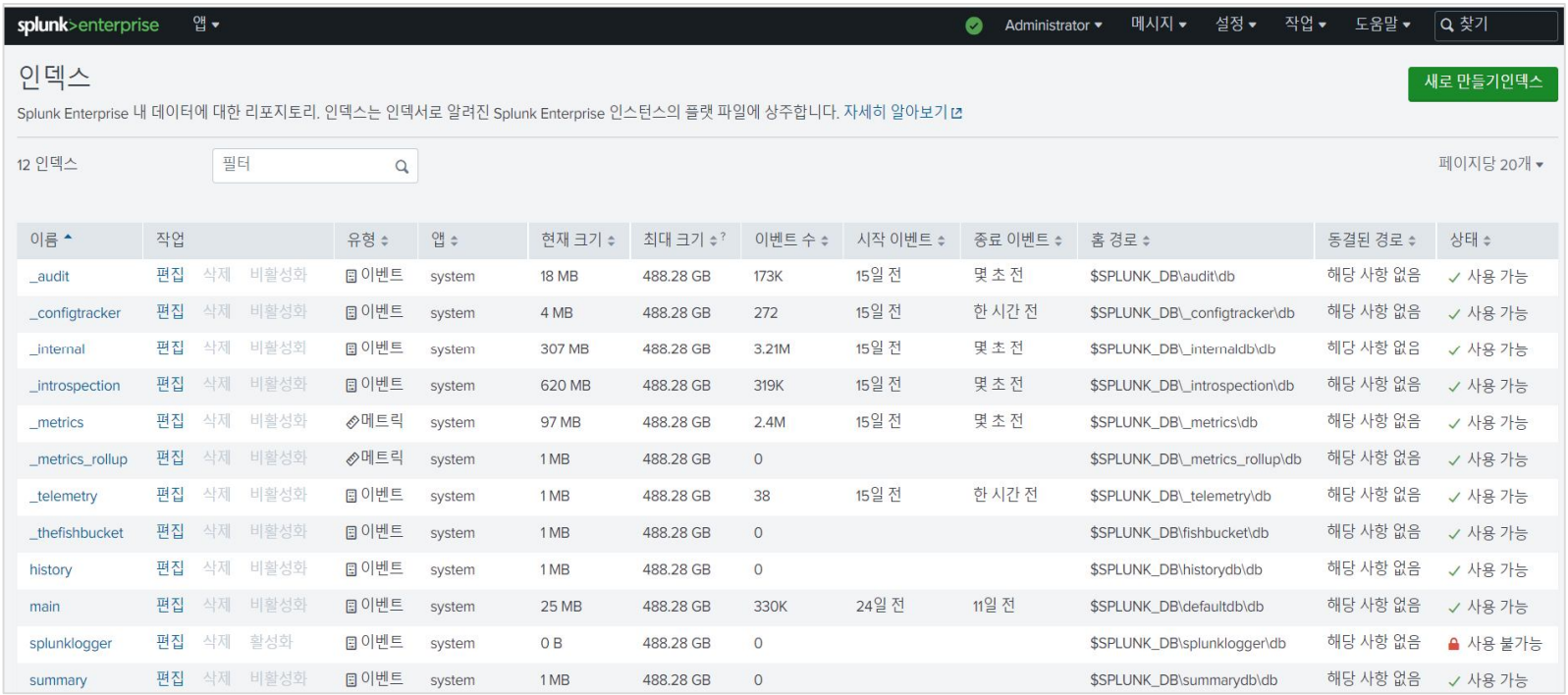
❷ SourceType 지정 (로그 필드명 지정)

❸ 데이터 추가 (로그 저장)

❹ URL Toolbox 설치


openssh : scp
SplunkServer
192.168.10.10/24
dns.zip
HUB/NAT
zeek
openssh : scp
ZeekIDS
192.168.10.20/24
WebServer
192.168.10.30/24
Sysmon
192.168.10.40/24

❶ 설정 > 데이터 > 인덱스 > 새로 만들기 인덱스



이름	작업	유형	앱	현재 크기	최대 크기	이벤트 수	시작 이벤트	종료 이벤트	홈 경로	동결된 경로	상태
_audit	편집 삭제 비활성화	이벤트	system	18 MB	488.28 GB	173K	15일 전	몇 초 전	$SPLUNK_DB\audit\db	해당 사항 없음	사용 가능
_configtracker	편집 삭제 비활성화	이벤트	system	4 MB	488.28 GB	272	15일 전	한 시간 전	$SPLUNK_DB_configtracker\db	해당 사항 없음	사용 가능
_internal	편집 삭제 비활성화	이벤트	system	307 MB	488.28 GB	3.21M	15일 전	몇 초 전	$SPLUNK_DB_internaldb\db	해당 사항 없음	사용 가능
_introspection	편집 삭제 비활성화	이벤트	system	620 MB	488.28 GB	319K	15일 전	몇 초 전	$SPLUNK_DB_introspection\db	해당 사항 없음	사용 가능
_metrics	편집 삭제 비활성화	메트릭	system	97 MB	488.28 GB	2.4M	15일 전	몇 초 전	$SPLUNK_DB_metrics\db	해당 사항 없음	사용 가능
_metrics_rollup	편집 삭제 비활성화	메트릭	system	1 MB	488.28 GB	0			$SPLUNK_DB_metrics_rollup\db	해당 사항 없음	사용 가능
_telemetry	편집 삭제 비활성화	이벤트	system	1 MB	488.28 GB	38	15일 전	한 시간 전	$SPLUNK_DB_telemetry\db	해당 사항 없음	사용 가능
_thefishbucket	편집 삭제 비활성화	이벤트	system	1 MB	488.28 GB	0			$SPLUNK_DB\fishbucket\db	해당 사항 없음	사용 가능
history	편집 삭제 비활성화	이벤트	system	1 MB	488.28 GB	0			$SPLUNK_DB\historydb\db	해당 사항 없음	사용 가능
main	편집 삭제 비활성화	이벤트	system	25 MB	488.28 GB	330K	24일 전	11일 전	$SPLUNK_DB\defaultdb\db	해당 사항 없음	사용 가능
splunklogger	편집 삭제 활성화	이벤트	system	0 B	488.28 GB	0			$SPLUNK_DB\splunklogger\db	해당 사항 없음	사용 불가능
summary	편집 삭제 비활성화	이벤트	system	1 MB	488.28 GB	0			$SPLUNK_DB\summarydb\db	해당 사항 없음	사용 가능

새 인덱스

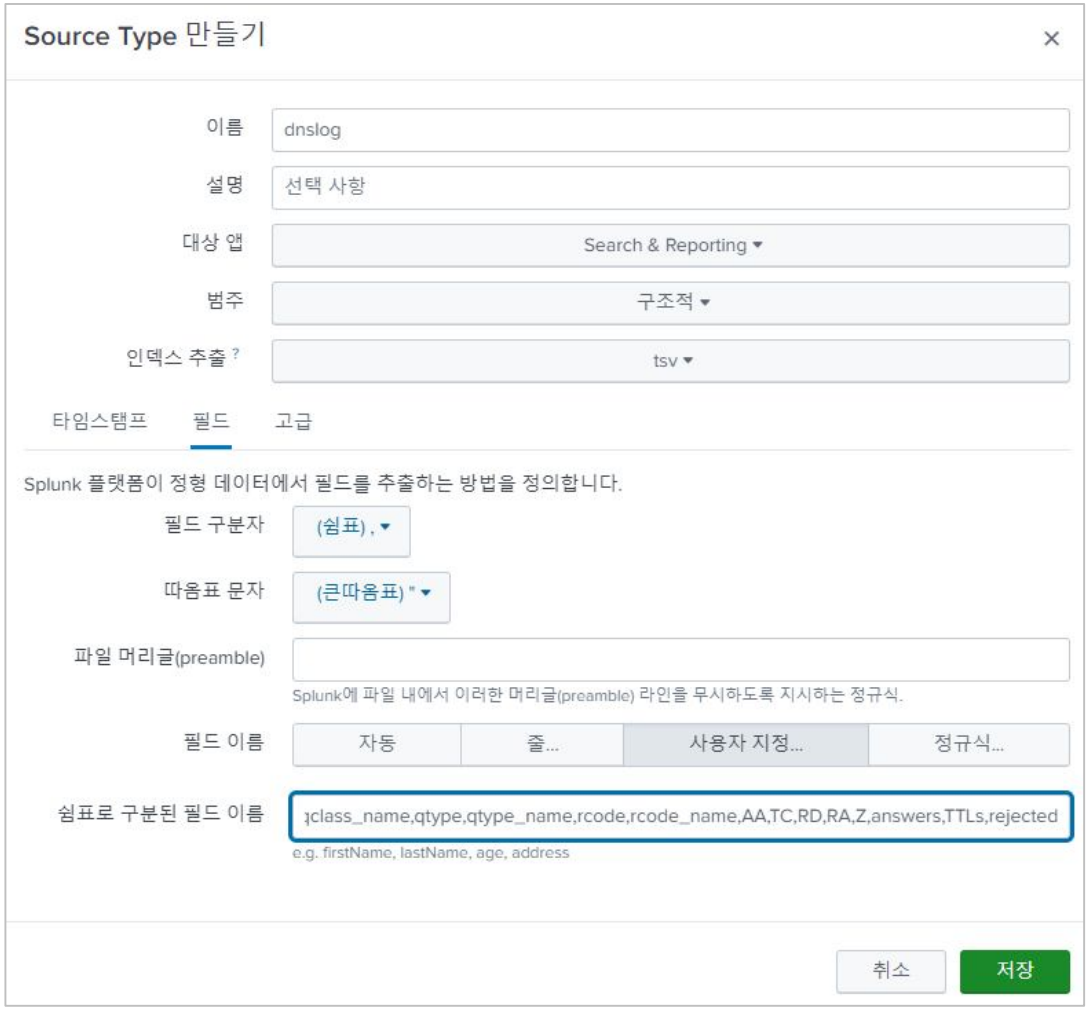
×

일반 설정

인덱스 이름	NetworkLog 인덱스 이름(예: INDEX_NAME)을 설정하십시오. index=INDEX_NAME을 사용하여 검색하십시오.
인덱스 데이터 유형	이벤트 / 메트릭 저장할 데이터 유형(이벤트 기반 또는 메트릭)
홈 경로	optional Hot/warm db 경로입니다. 기본적으로 비워 두십시오($SPLUNK_DB/INDEX_NAME/db).
Cold 경로	optional Cold db 경로입니다. 기본적으로 비워 두십시오($SPLUNK_DB/INDEX_NAME/colddb).
Thawed 경로	optional Thawed/resurrected db 경로입니다. 기본적으로 비워 두십시오($SPLUNK_DB/INDEX_NAME/thaweddb).
데이터 무결성 검사	Enable / Disable Splunk에서 데이터 무결성을 목적으로 데이터의 모든 조각에 대해 해시를 계산하도록 하려면 이 옵션을 활성화합니다.
전체 인덱스의 최대 크기	500 GB ▾ 전체 인덱스의 최대 대상 크기입니다.
Hot/Warm/Cold 버킷의 최대 크기	auto GB ▾ 버킷의 최대 대상 크기입니다. 높은 볼륨의 인덱스인 경우 'auto_high_volume'을 입력하십시오.
동결된 경로	optional 동결된 버킷 아카이브 경로입니다. Splunk가 동결된 버킷을 자동으로 아카이브하도록 하려면 이 항목을 설정하십시오.
앱	Search & Reporting ▾

저장 취소

❷ 설정 > 데이터 > Source Type > 새로 만들기 Source Type

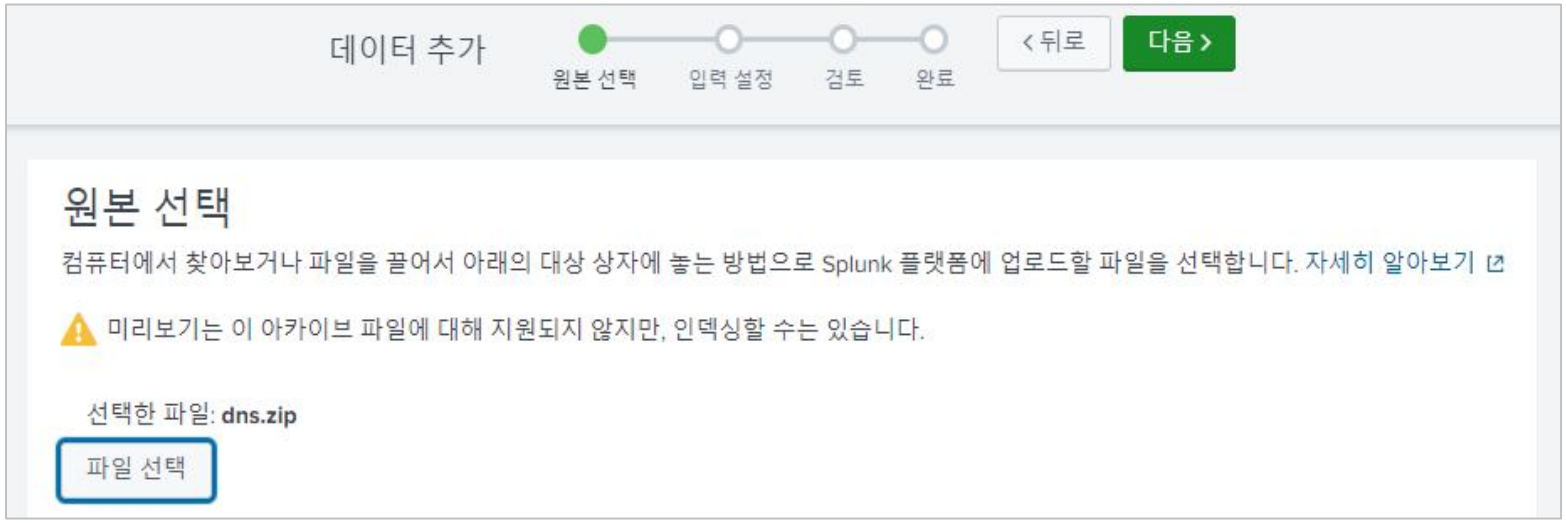


Zeek DNS 로그 필드

필드명	필드 설명
ts	시간정보로 Unix시간으로 표시
Uid	로그에 할당된 ID
Id.orig_h	송신지 IP주소
Id.orig_p	송신지 Port번호
Id.resp_h	수신지 IP 주소
Id.resp_p	수신지 Port 번호
Protocol	사용 프로토콜
trans_id	질의와 응답을 연결하는 ID
rtt	응답시간
query	도메인질의내용 DNS 서버에 질의한 도메인

필드명	필드 설명
qclass	질의클래스
qclass_name	질의클래스 이름
qtype	질의형식
qtype_name	질의형식이름
rcode	답변코드
rcode_name	질의한 도메인의 응답코드
AA	인증서버답변여부
TC	전체질의가 잘렸는지 여부
RD	재귀질의 요청여부
RA	재귀질의 가능여부
Z	예약된 필드로 사용하지 않음
Answers	DNS서버에서 반환한 답변내역
TTLs	도메인의 TTL값 질의 답변의 캐시보관기간 (3600초(1시간 기본))
Reject	질의가 거부됐는지 판단

❸ 데이터 추가


데이터 추가
원본 선택
입력 설정
검토
완료
‹ 뒤로
다음 ›
원본 선택
컴퓨터에서 찾아보거나 파일을 끌어서 아래의 대상 상자에 놓는 방법으로 Splunk 플랫폼에 업로드할 파일을 선택합니다. 자세히 알아보기
미리보기는 이 아카이브 파일에 대해 지원되지 않지만, 인덱싱할 수는 있습니다.
선택한 파일: dns.zip
파일 선택

데이터 추가

원본 선택 입력 설정 검토 완료

< 뒤로 검토 >

입력 설정

이 데이터 입력에 대해 다음과 같은 추가 매개 변수를 필요에 따라 설정하십시오.

Source type

source type은 Splunk 플랫폼이 모든 수신 데이터에 할당하는 기본 필드 중 하나입니다. 이를 통해 Splunk 플랫폼은 사용자가 어떤 데이터를 갖고 있는지 알고 인덱싱 중에 데이터 형식을 지능적으로 지정할 수 있습니다. source type은 데이터를 쉽게 검색할 수 있게 분류하는 방법이기도 합니다.

자동 선택 새로 만들기

dnslog

호스트

Splunk 플랫폼이 데이터를 인덱싱할 때 각 이벤트는 "host" 값을 수신합니다. 호스트 값은 이벤트가 발생하는 컴퓨터의 이름이어야 합니다. 사용자가 선택한 입력 유형에 따라 사용 가능한 설정 옵션이 결정됩니다. 자세히 알아보기

- (●) 상수 값
- ( ) 경로에 대한 정규식
- ( ) 경로 내 세그먼트

host 필드 값 SIEM-Host

인덱스

Splunk 플랫폼은 수신한 데이터를 선택된 인덱스에 이벤트로 저장합니다. 데이터의 source type을 파악하는 데 문제가 있는 경우 "테스트용" 인덱스를 만들어서 사용할 수 있습니다. 테스트용 인덱스를 사용하면 프로덕션 인덱스에 영향을 주지 않고 설정 문제를 해결할 수 있습니다. 나중에 언제든지 이 설정을 변경할 수 있습니다. 자세히 알아보기

인덱스 dnslog 새 인덱스 만들

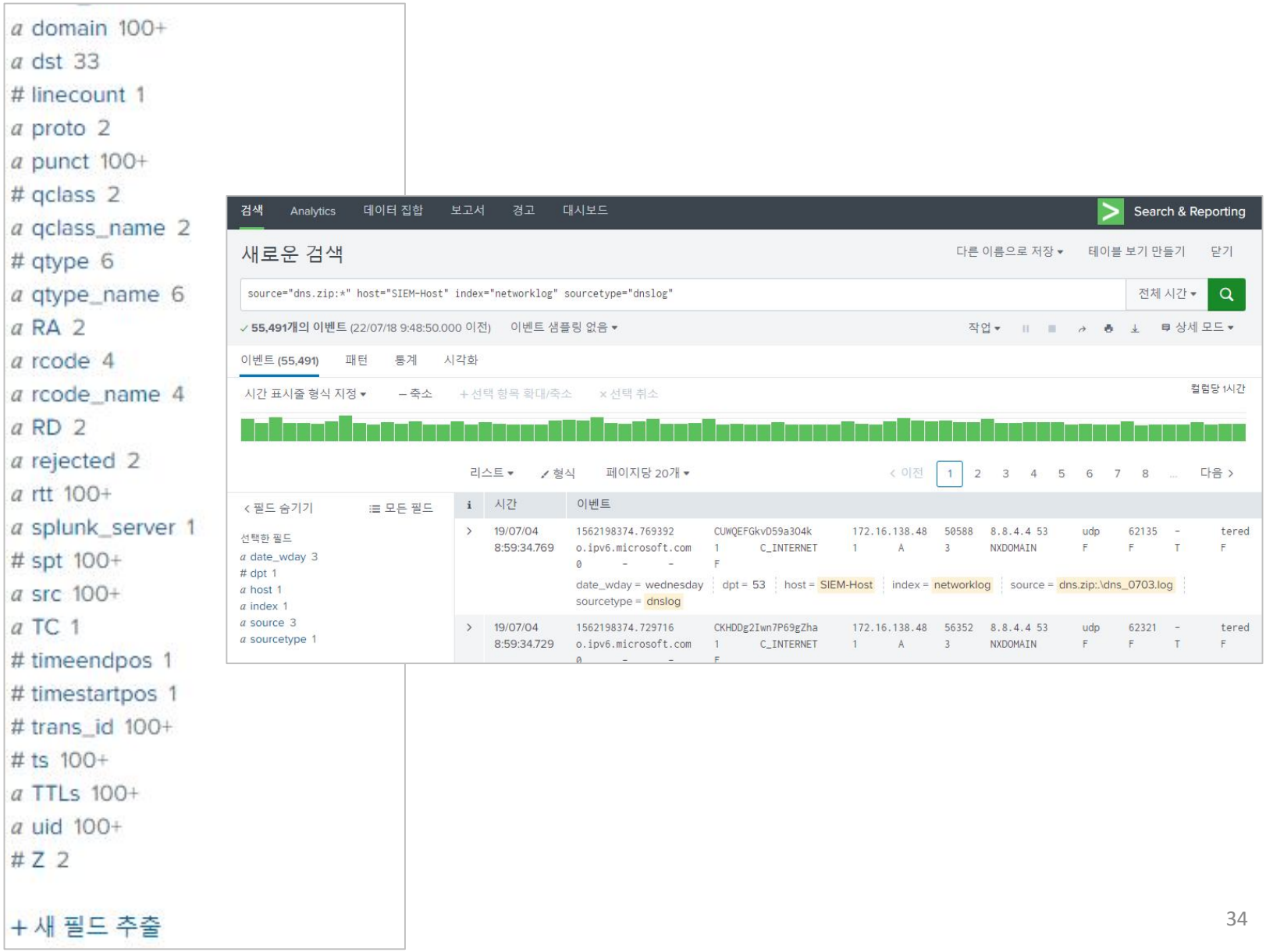
데이터 추가

원본 선택 입력 설정 검토 완료

< 뒤로 제출 >

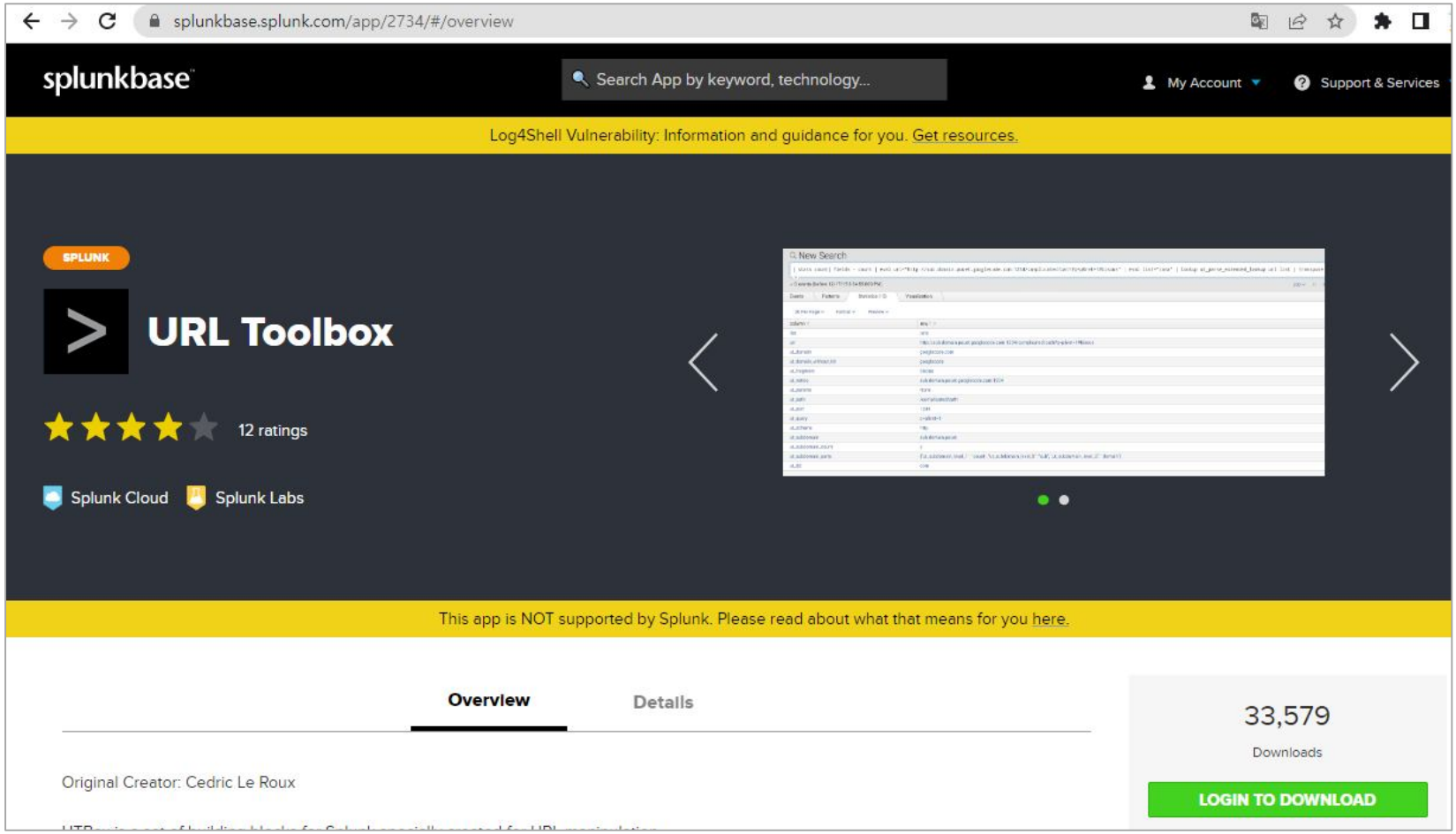
검토

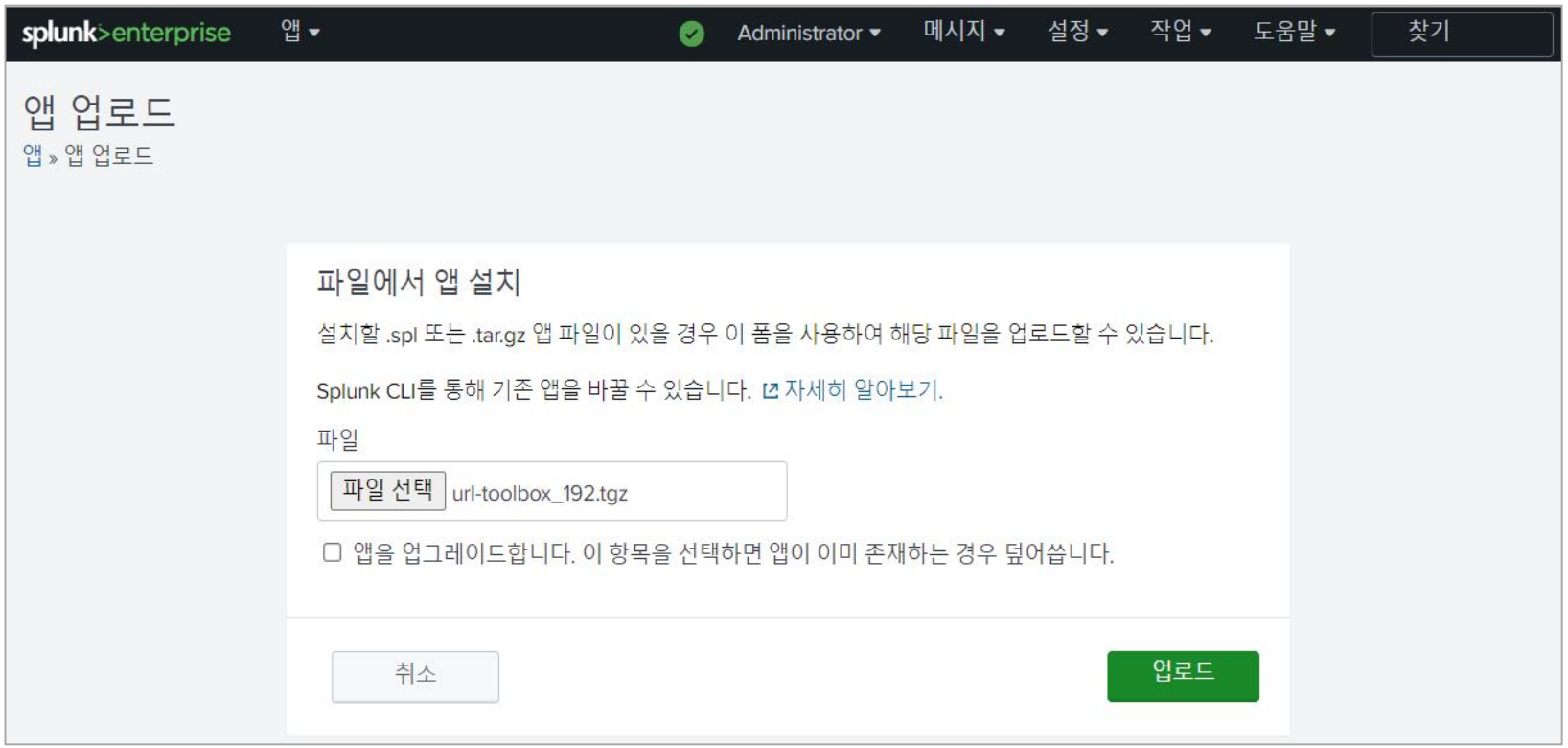
입력 유형	업로드된 파일
파일 이름	dns.zip
Source Type	dnslog
호스트	SIEM-Host
인덱스	networklog

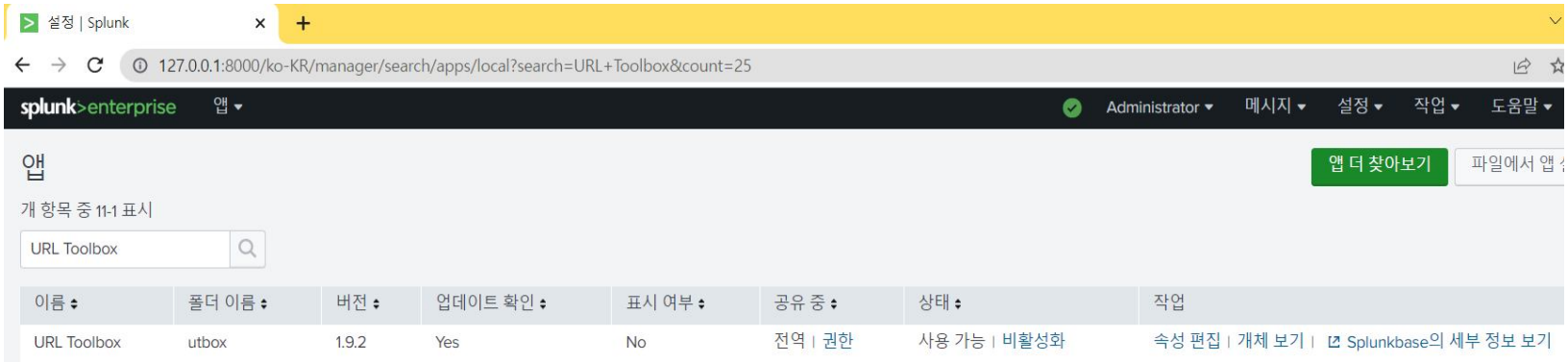

a domain 100+
a dst 33
linecount 1
a proto 2
a punct 100+
qclass 2
a qclass_name 2
qtype 6
a qtype_name 6
a RA 2
a rcode 4
a rcode_name 4
a RD 2
a rejected 2
a rtt 100+
a splunk_server 1
spt 100+
a src 100+
a TC 1
timeendpos 1
timestartpos 1
trans_id 100+
ts 100+
a TTLs 100+
a uid 100+
Z 2
+ 새 필드 추출
검색
Analytics
데이터 집합
보고서
경고
대시보드
Search & Reporting
새로운 검색
다른 이름으로 저장
테이블 보기 만들기
닫기
source="dns.zip:*" host="SIEM-Host" index="networklog" sourcetype="dnslog"
전체 시간
55,491개의 이벤트 (22/07/18 9:48:50.000 이전)
이벤트 샘플링 없음
작업
상세 모드
이벤트 (55,491)
패턴
통계
시각화
시간 표시줄 형식 지정
축소
+ 선택 항목 확대/축소
× 선택 취소
컬럼당 1시간
리스트
형식
페이지당 20개
이전
1 2 3 4 5 6 7 8 ...
다음
필드 숨기기
모든 필드
선택한 필드
a date_wday 3
dpt 1
a host 1
a index 1
a source 3
a sourcetype 1
시간
이벤트
19/07/04 8:59:34.769
1562198374.769392 CUWQEFGkvD59a3O4k 172.16.138.48 50588 8.8.4.4 53 udp 62135 - tered
o.ipv6.microsoft.com 1 C_INTERNET 1 A 3 NXDOMAIN F F T F
0 - - F
date_wday = wednesday
dpt = 53
host = SIEM-Host
index = networklog
source = dns.zip:.\dns_0703.log
sourcetype = dnslog
19/07/04 8:59:34.729
1562198374.729716 CKHDDg2Iwn7P69gZha 172.16.138.48 56352 8.8.4.4 53 udp 62321 - tered
o.ipv6.microsoft.com 1 C_INTERNET 1 A 3 NXDOMAIN F F T F
0 - - F

❹ URL Toolbox 설치

https://splunkbase.splunk.com/app/2734/#/overview




splunk>enterprise
앱
Administrator
메시지
설정
작업
도움말
찾기
앱 업로드
앱 » 앱 업로드
파일에서 앱 설치
설치할 .spl 또는 .tar.gz 앱 파일이 있을 경우 이 폼을 사용하여 해당 파일을 업로드할 수 있습니다.
Splunk CLI를 통해 기존 앱을 바꿀 수 있습니다. 자세히 알아보기.
파일
파일 선택
url-toolbox_192.tgz
앱을 업그레이드합니다. 이 항목을 선택하면 앱이 이미 존재하는 경우 덮어씁니다.
취소
업로드


설정 | Splunk
127.0.0.1:8000/ko-KR/manager/search/apps/local?search=URL+Toolbox&count=25
splunk>enterprise
앱
Administrator
메시지
설정
작업
도움말
앱
앱 더 찾아보기
개 항목 중 11-1 표시
URL Toolbox
이름
폴더 이름
버전
업데이트 확인
표시 여부
공유 중
상태
작업
URL Toolbox
utbox
1.9.2
Yes
No
전역 | 권한
사용 가능 | 비활성화
속성 편집 | 개체 보기 | Splunkbase의 세부 정보 보기

모든 설정

Knowledge Object 재할당

개 항목 중 117-17 표시

App URL Toolbox (utbox) 소유자 모두 앱에서 생성됨 필터 25 페이지당

이름	설정 유형	소유자	App	공유 중	상태
ut_bayesian(1)	macros	admin	utbox	전역 | 권한	사용 가능 | 비활성화
ut_bayesian_lookup	transforms-lookup	admin	utbox	전역 | 권한	사용 가능 | 비활성화
ut_countset(2)	macros	admin	utbox	전역 | 권한	사용 가능 | 비활성화
ut_countset_lookup	transforms-lookup	admin	utbox	전역 | 권한	사용 가능 | 비활성화
ut_levenshtein(2)	macros	admin	utbox	전역 | 권한	사용 가능 | 비활성화
ut_levenshtein_lookup	transforms-lookup	admin	utbox	전역 | 권한	사용 가능 | 비활성화
ut_meaning(1)	macros	admin	utbox	전역 | 권한	사용 가능 | 비활성화
ut_meaning_lookup	transforms-lookup	admin	utbox	전역 | 권한	사용 가능 | 비활성화
ut_parse(2)	macros	admin	utbox	전역 | 권한	사용 가능 | 비활성화
ut_parse_extended(2)	macros	admin	utbox	전역 | 권한	사용 가능 | 비활성화
ut_parse_extended_lookup	transforms-lookup	admin	utbox	전역 | 권한	사용 가능 | 비활성화
ut_parse_simple(1)	macros	admin	utbox	전역 | 권한	사용 가능 | 비활성화
ut_parse_simple_lookup	transforms-lookup	admin	utbox	전역 | 권한	사용 가능 | 비활성화
ut_shannon(1)	macros	admin	utbox	전역 | 권한	사용 가능 | 비활성화
ut_shannon_lookup	transforms-lookup	admin	utbox	전역 | 권한	사용 가능 | 비활성화
ut_suites(2)	macros	admin	utbox	전역 | 권한	사용 가능 | 비활성화
ut_suites_lookup	transforms-lookup	admin	utbox	전역 | 권한	사용 가능 | 비활성화

DNS 로그 분석

- DNS 로그는 사용자의 **<u>네트워크 접속 행위를 분석하는데 가장 좋은 데이터 소스</u>**
- 내부망 DNS 로그 분석

  - 내부 사용자가 인터넷 또는 내부 업무망을 접속 시 발생하는 로그이기 때문

  - 공격자의 **악성코드에 감염된 내부망 PC가** 내부 데이터 획득을 목표로 활동하는 상황을 파악할 수 있기 때문
- DNS 로그 주요 정보는 사용자가 조회하는 도메인 이름

2) DNS로그를 이용한 네트워크 현황 분석 항목

❶ Top 10 도메인 현황

❷ Top 10 도메인 요청 IP 현황

❸ 도메인 응답코드 현황

* 현황이란 현재 발생하는 상황을 확인하는 것

❶ Top 10 도메인 현황

- 사용자들이 가장 많이 접속한 도메인 10개를 보여줌
- 많이 접속한다는 것은 많은 사용자가 접속한다는 뜻이지만 소수의 클라이언트가 많이 접속할 수도 있다는 뜻이기도 함

  (예) 동일한 도메인을 10분 동안 60번씩 요청할 경우, 자동화된 프로그램으로 동작한다고 추측 가능
- 네트워크 접속 행위를 분석 시 해당 트래픽이 사용자가 발생시킨 것인지, 자동 프로그램이 일으킨 행위인지를 분석의 기준으로 삼으면 좋음

* <u>현황분석은 숫자를 보여주지만 해당 숫자에서 이상 징후를 유추해야 함</u>

```
index=dnslog sourcetype=dnslog dpt=53 domain!="*.arpa" domain!="-"
| eval list="mozilla"
| `ut_parse(domain,list)`
| top showperc=f limit=10 ut_netloc
```

ut_netloc	count
teredo.ipv6.microsoft.com	47565
gms.ahnlab.com	713
crl.microsoft.com	564
google.com	563
ctldl.windowsupdate.com	520
www.microsoft.com	194
s-iavs9x.avcdn.net	190
s-avi18.avcdn.net	172
tus1gwynwapex01.symantec.com	153
tags.baikalize.com	142

domain!="*.arpa" domain!="-"	Reverse 도메인 제외 또는 Domain필드가 없는 경우 제외

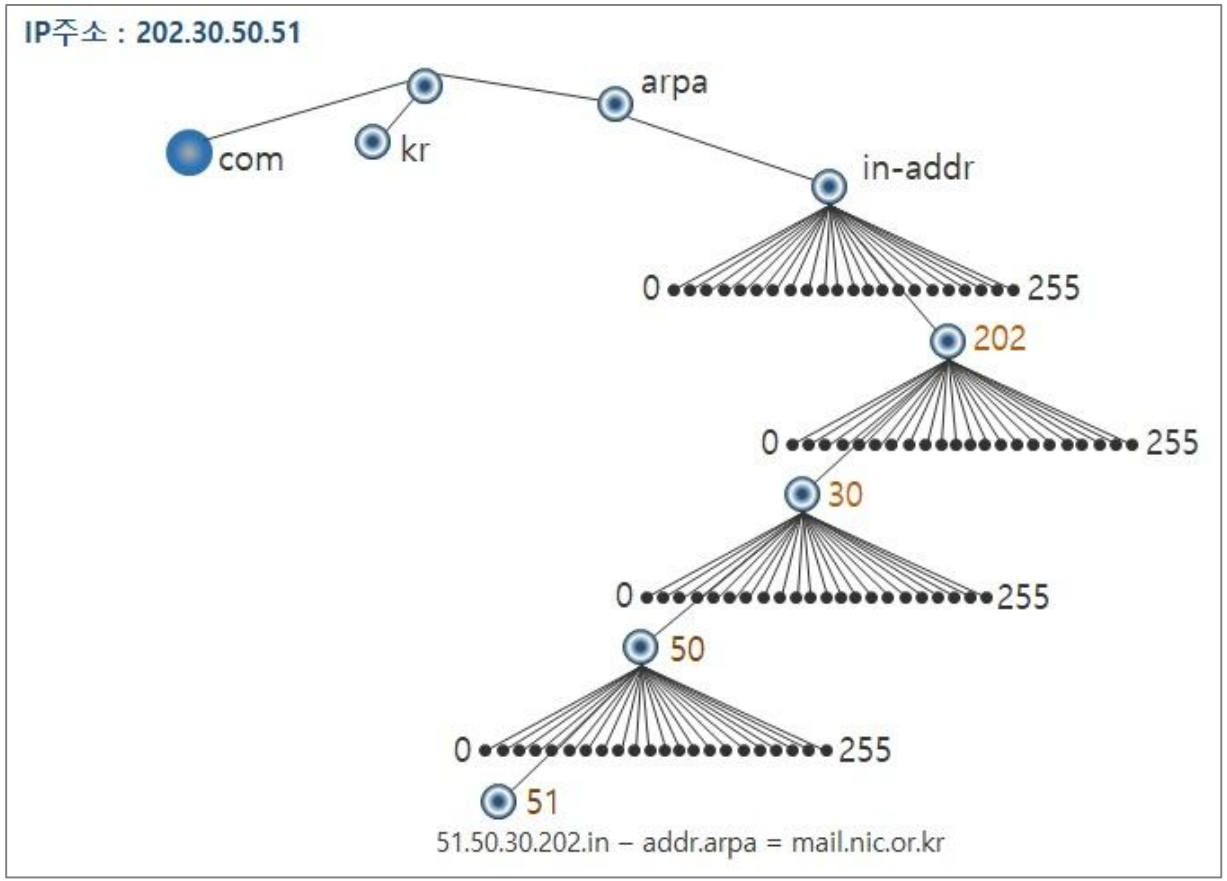
* Reverse DNS (Reverse Domain)

- 역방향 조회로 IP주소에 대응하는 도메인 이름 조회하는 것
- PTR 레코드 : IP주소에 해당하는 숫자와 특수 문자열 in-addr.arpa로 구성

(예) 202.131.27.71의 RTP 레코드 확인

```
C:\>nslookup -type=ptr 202.131.27.71
서버:    acns.bora.net
Address:  1.214.68.2

권한 없는 응답:
71.27.131.202.in-addr.arpa      name = mx-1.naver.com
```

Reverse Domain (Inverse domain 또는 PTR recode)



eval list="mozilla" `ut_parse(domain, list)`	TLD 목록은 mozilla에서 지정한 형식을 따름 Domain은 도메인 값이 지정한 필드명
top showperc=f limit=10 ut_netloc	10개의 도메인을 추출 (limit=0은 내부 사용자 조회한 모든 도메인을 보여줌) showperc=f 데이터가 점유하는 비율을 숨김

최상위 도메인(Top-level domain, TLD)

- 도메인 네임의 가장 마지막 부분 **(예) www.sks.com 의 TLD는 .com**

- TLD는 일반최상위 도메인(.com)과 국가코드 최상위 도메인(kr)로 나뉨

<<URL Toolbox가 지원하는 매크로>>

ut_netloc : 전체 도메인을 보여줌

ut_domain : 서브도메인을 제외한 도메인 명을 보여줌

ut_subdomain : 서버 도메인만 보여줌

ut_tld: 도메인에서 utl값만 보여줌

서브도메인(subdomain)
- 도메인 소유자가 생성하는 도메인명

```
index=dnslog sourcetype=dnslog domain!="-"
| eval list="mozilla"
| `ut_parse(domain,list)`
| table ut_netloc, ut_domain, ut_subdomain, ut_domain, ut_domain_without_tld, ut_tld
| dedup ut_netloc
```

ut_netloc
전체 도메인

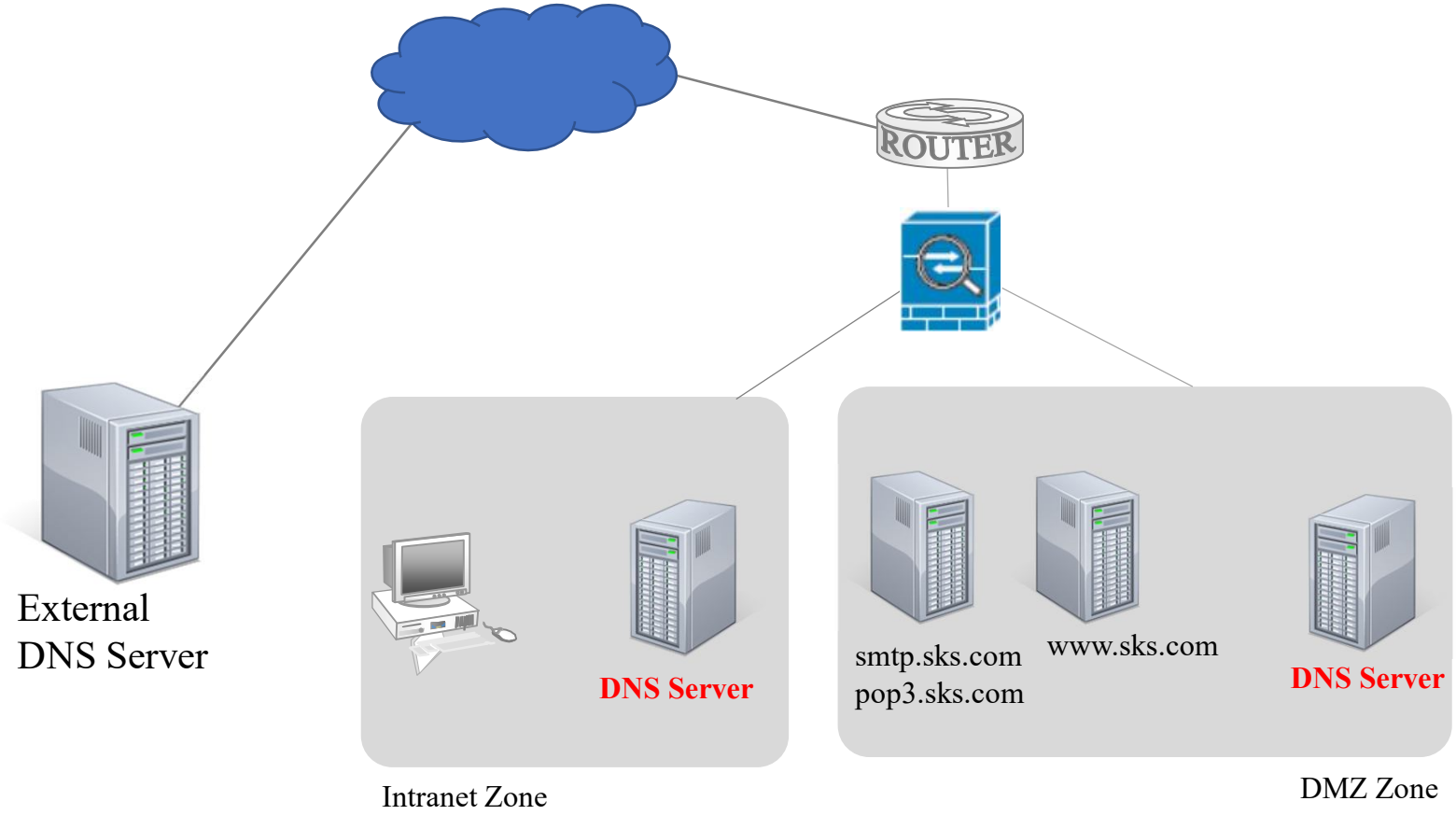
ut_domain
서브도메인을
제외한 도메인 명

ut_subdomain
서브 도메인

ut_tld
도메인에서
utl값만 보여줌

ut_netloc	ut_domain	ut_subdomain	ut_domain_without_tld	ut_tld
teredo.ipv6.microsoft.com	microsoft.com	teredo.ipv6	microsoft	com
bambooroot.s3.amazonaws.com	amazonaws.com	bambooroot.s3	amazonaws	com
crl.microsoft.com	microsoft.com	crl	microsoft	com
ctldl.windowsupdate.com	windowsupdate.com	ctldl	windowsupdate	com
nexus.officeapps.live.com	live.com	nexus.officeapps	live	com
fe2.update.microsoft.com	microsoft.com	fe2.update	microsoft	com
download.microsoft.com	microsoft.com	download	microsoft	com
www.microsoft.com	microsoft.com	www	microsoft	com
ds.download.windowsupdate.com	windowsupdate.com	ds.download	windowsupdate	com
gms.ahnlab.com	ahnlab.com	gms	ahnlab	com

내부망 DNS 서버


ROUTER
External
DNS Server
DNS Server
Intranet Zone
smtp.sks.com
pop3.sks.com
www.sks.com
DNS Server
DMZ Zone

- 내부망 도메인은 기업이나 조직에서 사용하는 도메인
- 내부 서버 도메인을 조회하는 현황 파악 검색 명령어

```
index=dnslog sourcetype=dnslog dpt=53 domain!="*.arpa" domain!="-"
| eval list="mozilla"
| `ut_parse(domain,list)`
|  where match(ut_domain, “sks.com$”)
| top showperc=f limit=10 ut_netloc
```

- **내부 도메인의 집중 질의**
  - 공격자가 내부를 탐색하는 lateral movement 공격일 수 있음
  - 감염됨 PC가 인터넷이 위치하는 C2서버 접속을 위한 준비일 수도 있음
- 보안 담당자는 **인터넷으로 향하는 도메인과 내부망으로 향하는 도메인을 구분해서** 네트워크 접속 유형을 파악

Lateral movement

- 내부망 공격이라 부름
- 조직 내부로 침투한 위협이 최종 타깃 시스템을 찾기 위해 내부망에서 이동하는 것
- 횡적이동: Client to Client 또는 Server to Server 이동
- 종적이동: Clietn to Server 또는 Server to Client
- 주위 시스템을 감염시키는 것이 목표

❷ Top 10 도메인 요청 IP 현황

- 여러 명이 조회해서 조회 숫자가 많은 도메인과 한 명이 집중해서 조회한 도메인 구분
- 도메인과 해당 도메인을 접속한 송신지 IP주소를 동시에 검색

```
index=dnslog sourcetype=dnslog dpt=53 domain!="*.arpa" domain!="-"
| eval list="mozilla" | `ut_parse(domain,list)` | top showperc=f src, ut_netloc
```

src	ut_netloc	count
172.16.146.107	teredo.ipv6.microsoft.com	35199
172.16.138.48	teredo.ipv6.microsoft.com	12366
172.16.138.48	gms.ahnlab.com	699
172.16.146.107	ctldl.windowsupdate.com	513
172.16.146.107	crl.microsoft.com	469
172.16.146.107	www.microsoft.com	194
172.16.146.107	tus1gwynwapex01.symantec.com	153
172.16.158.111	tags.baikalize.com	133
172.16.138.48	bambooroot.s3.amazonaws.com	107
172.16.138.48	nexus.officeapps.live.com	102

❸ 도메인 응답코드 현황

- 도메인 응답코드(reply code)는 사용자가 요청한 도메인을 DNS서버가 응답한 결과 값
- Zeek의 응답코드 필드는 rcode와 rcode_name

rcode	rcode_name	설명
0	NoError	오류없음
1	FormErr	Query 형식 오류
2	SevFail	DNS 서버 자체의 문제로 실패
3	NXDomain	사용자가 질의한 도메인명이 존재하지 않음 Non-eXistent Domain
4	NotImp	DNS 서버가 해당 질의를 지원하지 않음
5	Refused	정책적인 이유로 질의를 거절함

```
index=dnslog sourcetype=dnslog domain!="-" rcode_name= "NXDomain"
| top showperc=f src, domain
```

* NXDomain이 빈번하게 발생하는 도메인과 해당 질의를 발생하는 송신지 모니터링

src	ut_netloc	count
172.16.146.107	teredo.ipv6.microsoft.com	35199
172.16.138.48	teredo.ipv6.microsoft.com	12366
172.16.138.48	gms.ahnlab.com	699
172.16.146.107	ctldl.windowsupdate.com	513
172.16.146.107	crl.microsoft.com	469
172.16.146.107	www.microsoft.com	194
172.16.146.107	tus1gwynwapex01.symantec.com	153
172.16.158.111	tags.baikalize.com	133
172.16.138.48	bambooroot.s3.amazonaws.com	107
172.16.138.48	nexus.officeapps.live.com	102

- NXDomain 또는 Refused는 사용자가 질의한 도메인이 없다는 것임
- 도메인명을 잘못 입력한 경우 해당 도메인이 등록되지 않은 경우 오류가 발생

  - 지속적인 NXDomain 응답은 점검 대상

- **NXDomain이 지속적으로 발생하는 경우**

  - 감염된 PC가 사라진 도메인의 접속을 시도

  - DGA로 생성된 도메인이 인터넷에 아직 등록되지 않은 경우

    * DGA (Domain Generation Algorithms)

      - 도메인 이름을 주기적으로 동적으로 생성하는 알고리즘

3) DNS 이상징후

❶ 비정상적인 서브 도메인 길이

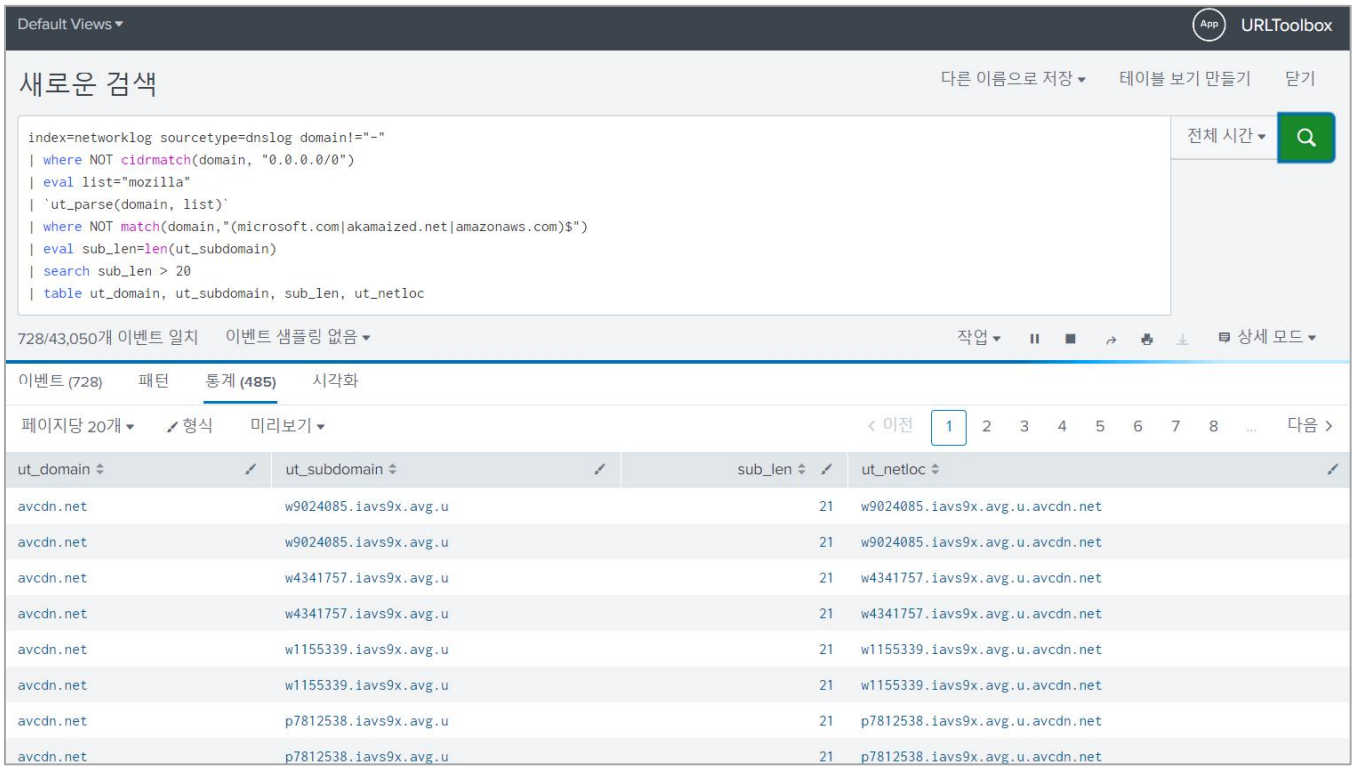
❷ 비허가 DNS 사용/DNS 터널링

❶ 비정상적인 서브 도메인 길이

- 한국인터넷진흥원의 도메인 관리 원칙 : 도메인명 2~63자로 구성
- 서브도메인은 도메인 소유자가 생성하는 도메인명
- 비정상적인 도메인 길이는 주로 서브도메인을 의미
- 최근 클라우드서비스(CDN, Contents Delivery Network)는 도메인

  도메인 포워딩 기술을 이용하므로 서브도메인이 길어 질 수 있음
- 해당 도메인을 화이트 리스트 등재 또는 예외처리를 하면 비정상적으로 길이가 긴 서브 도메인을 쉽게 찾을 수 있음

```
index=networklog sourcetype=dnslog domain!="-"
| where NOT cidrmatch(domain, "0.0.0.0/0")
| eval list="mozilla"
| `ut_parse(domain, list)`
| where NOT match(domain,"(microsoft.com|akamaized.net|amazonaws.com)$")
| eval sub_len=len(ut_subdomain)
| search sub_len > 20
| table ut_domain, ut_subdomain, sub_len, ut_netloc
```



ut_domain	ut_subdomain	sub_len	ut_netloc
avcdn.net	w9024085.iavs9x.avg.u	21	w9024085.iavs9x.avg.u.avcdn.net
avcdn.net	w9024085.iavs9x.avg.u	21	w9024085.iavs9x.avg.u.avcdn.net
avcdn.net	w4341757.iavs9x.avg.u	21	w4341757.iavs9x.avg.u.avcdn.net
avcdn.net	w4341757.iavs9x.avg.u	21	w4341757.iavs9x.avg.u.avcdn.net
avcdn.net	w1155339.iavs9x.avg.u	21	w1155339.iavs9x.avg.u.avcdn.net
avcdn.net	w1155339.iavs9x.avg.u	21	w1155339.iavs9x.avg.u.avcdn.net
avcdn.net	p7812538.iavs9x.avg.u	21	p7812538.iavs9x.avg.u.avcdn.net
avcdn.net	p7812538.iavs9x.avg.u	21	p7812538.iavs9x.avg.u.avcdn.net

```
index=networklog sourcetype=dnslog domain!="-"
| where NOT cidrmatch(domain, "0.0.0.0/0")
```

- 도메인 필드 값이 IP 주소가 아닌 이벤트 검색

```
| eval list="mozilla"
| `ut_parse(domain, list)`
```

- URL Toolbox 매크로를 이용해서 도메인 분석

```
| where NOT match(domain,"(microsoft.com|akamaized.net|amazonaws.com)$")
| eval sub_len=len(ut_subdomain)
```

- ut_domain 값 비교
- Match 함수의 두번째 인자는 비교대상, 여러 개의 값을 한번에 비교
- $는 비교 도메인이 비교 대상의 마지막 문자열인지 검사
- microsoft.com, akamaized.net, amazonaws.com로 끝나지 않는 이벤트 검색
- 배제 사이트는 클라우드 또는 CDN 서비스를 시행하면서 서브도메인 길이가 김

```
| eval sub_len=len(ut_subdomain)
```

- ut_subdomain 필드값의 길이를 구함

```
| search sub_len > 20
```

- 서브 도메인 필드 값의 길이가 20이상인 이벤트를 구함

```
| table ut_domain, ut_subdomain, sub_len, ut_netloc
```

- 도메인, 서브 도메인, 서브도메인 길이, 전체 도메인을 나열

❷ 비허가 DNS 사용/DNS 터널링

- 직접공격보다는 비정상적인 네트워크 탐지가 목적
- 호스트가 내부망에서 지정한 DNS 서버가 아닌 임의의 DNS 서버에 질의를 전송하는 증상
- 정책 수집의 선행 조건

  - 기접 내부망에 전용 DNS 서버를 구축하고 운영

  - 내부 클라이언트나 서버가 반드시 내부 DNS 서버를 사용하도록 IP환경설정

  * 내부망 모든 호스트가 DNS 서비스를 요청하는 현황을 모니터리 가능

- DNS 싱크홀과 같은 보안 기법 적용

  - DNS 싱크홀 : DNS 서버에 악성 도메인을 등록해서 접속을 차단

❷ 비허가 DNS 사용/DNS 터널링

- 내부 호스트의 도메인 요청 질의를 분석하면 악성 도메인 접속을 시도하거나 접속했는지를 알 수 있음

- 출발지가 내부 지정 DNS 서버가 아니고 도메인 질의 대상이 내부망 호스트인 경우 비정상 접속을 시도한 것으로 판별

```
index=networklog sourcetype=dnslog (dst!="172.16.142.11" AND dst!="172.16.142.12")
(src!="172.16.142.11" AND src!="172.16.142.12")
| stats count by dst
| sort - count
```

dst	count
8.8.8.8	13231
8.8.4.4	4450
168.126.63.1	267
164.124.101.2	170
174.35.55.22	132
66.114.55.22	104
1.214.68.2	63

```
index=networklog sourcetype=dnslog (dst!="172.16.142.11" AND dst!="172.16.142.12")
(src!="172.16.142.11" AND src!="172.16.142.12")
```

- DNS 서버 주소 : 172.16.142.11, 172.16.142.12
- 송수신지가 DNS 서버가 아닌 것을 추출
- 내부망 호스트는 DNS 조회를 위해서 반드시 지정한 DNS 서버에 접속해야 함
- DNS 질의 패킷의 목적지는 반드시 내부망에서 지정한 DNS 서버여야 함
- 출발지가 내부 지정 DNS 서버가 아니고 도메인 질의 대상이 내부망 호스트인 경우 비정상 접속을 시도한 것으로 판별